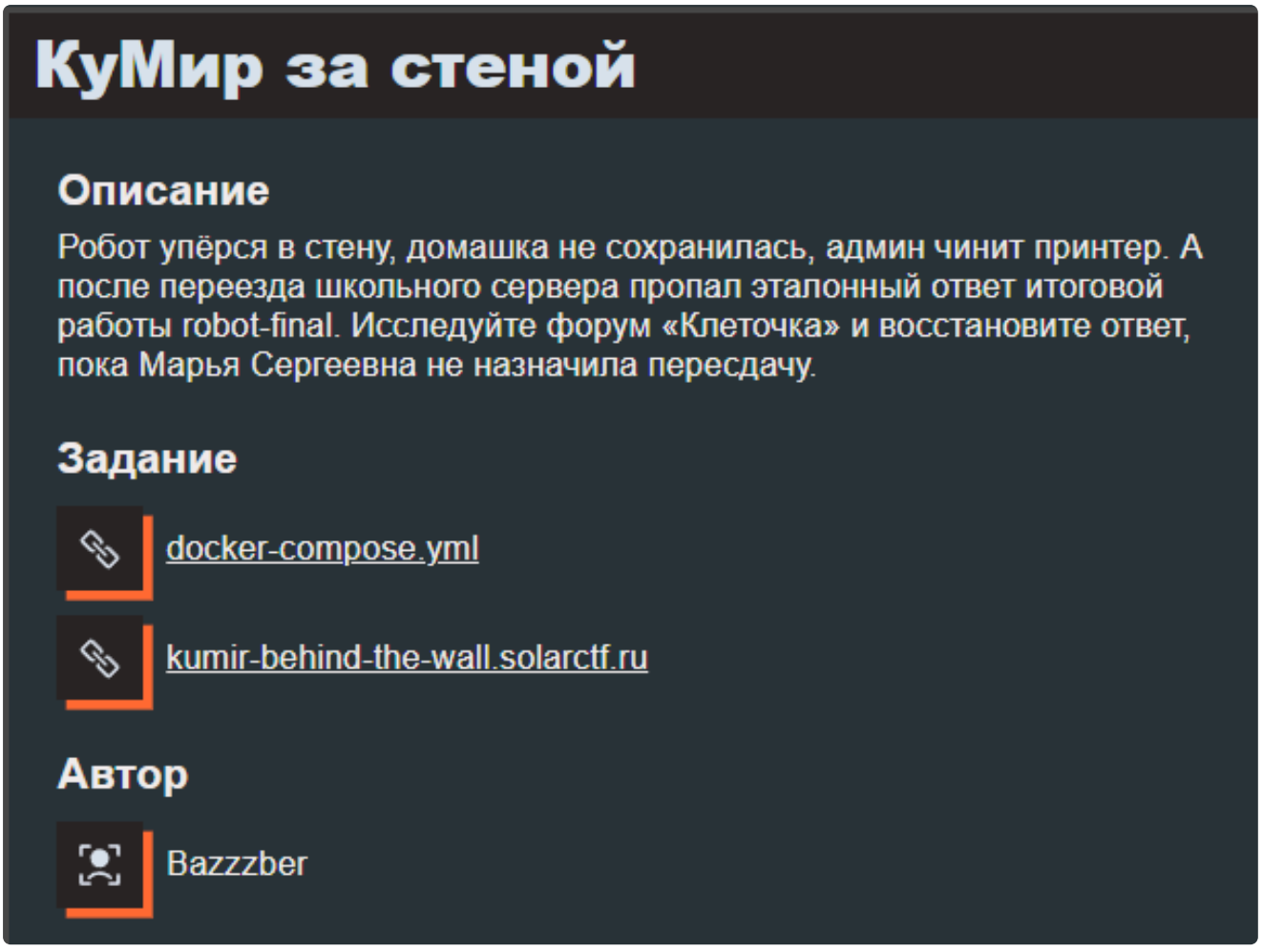
КуМир за стеной

Категория	Web
Уязвимость	SSRF
Баллы	100

Текст задания:



Анализ `docker-compose.yml`:

Содержимое:

```
services:
  web:
    ports:
      - "8000:8000"

    networks:
      - govnonet
      - edge

    depends_on:
      kumir-checker:
        condition: service_healthy

  kumir-checker:
    networks:
      - govnonet
    healthcheck:
      test:
        - CMD
        - python3
        - -c
        - "import urllib.request;
urllib.request.urlopen('http://127.0.0.1:8081/health', timeout=2).read()"
      interval: 10s
      timeout: 3s
      retries: 3
      start_period: 10s

networks:
  govnonet:
    driver: bridge
    internal: true

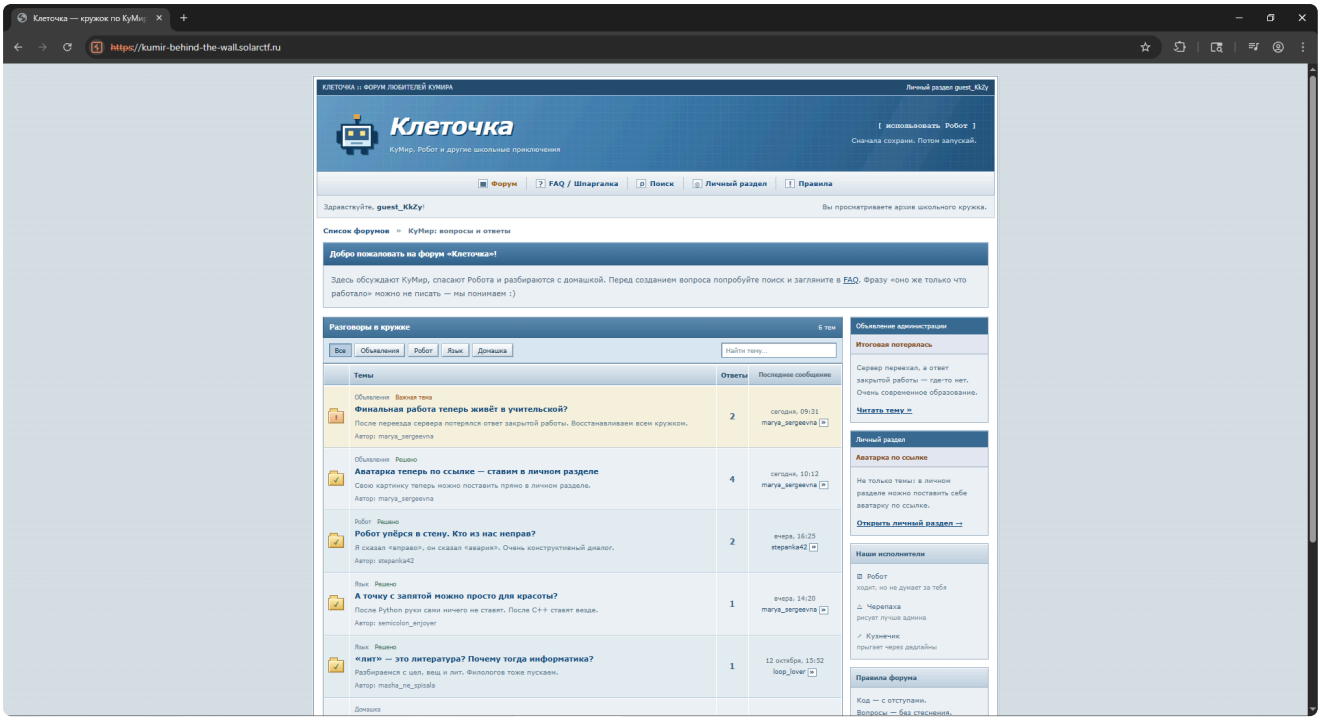
  edge:
    driver: bridge
    driver_opts:
      com.docker.network.bridge.enable_ip_masquerade: "false"
```

Анализ:

- web подключён к двум сетям — govnonet и edge.
- kumir-checker подключён к govnonet, которая объявлена внутренней сетью. Поэтому веб-приложение потенциально может обращаться к kumir-checker по внутреннему адресу, хотя сам сервис не опубликован на хосте через ports.

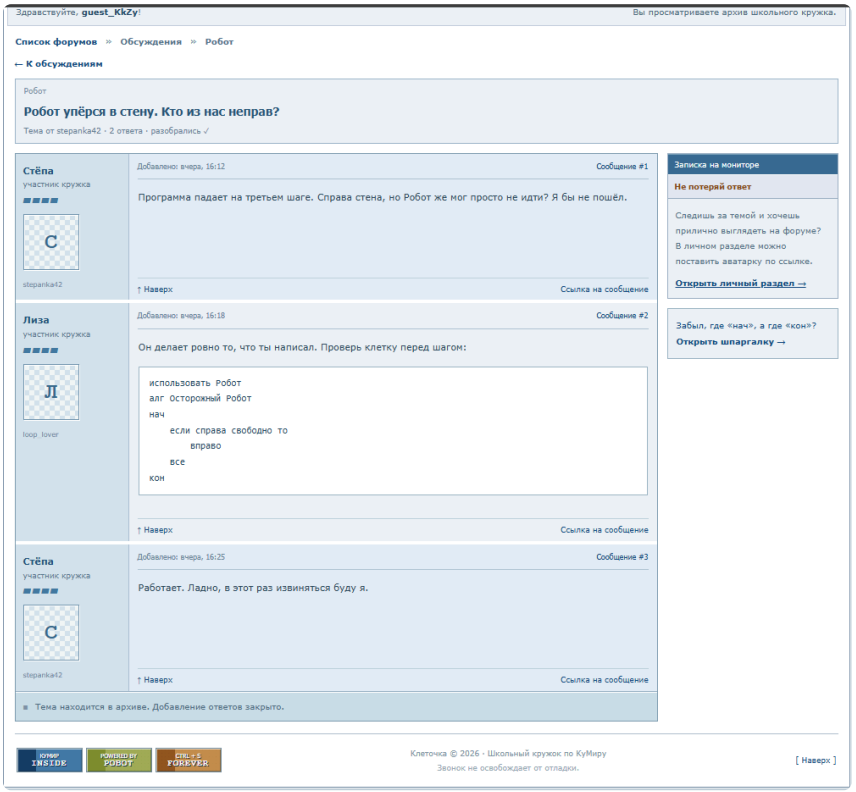
Гипотеза: Проверить внутренний сервис на SSRF

Разведка:



В личном кабинете обнаружена функция установки аватара по URL. Это потенциальная точка входа для SSRF: если сервер загружает изображение самостоятельно и не ограничивает адрес назначения, можно попытаться обратиться к внутренним сервисам.
Для проверки используется адрес kumir-checker:8081, обнаруженный при анализе конфигурации Docker.

Анализ комментариев:



В обсуждении задания обнаружена подсказка о перемещении робота: при свободном пространстве справа нужно двигаться вправо.

Этап 1. Подтверждение SSRF:

Проверка url: `http://kumir-checker:8081/robot-final`

Ответ burp:

```
"diagnostic":
"Kumir 2 teacher checker\nGET /teacher/check?
task=robot-final&answer=<one-line answer>\n..."}
```

Анализ:
Запрос подтвердил возможность обращения к внутреннему сервису, но выбранный endpoint без необходимых параметров не позволил получить флаг.

Этап 2. Получение флага:

Проверка url:
В тексте комментария была подсказка, поэтому проверяю endpoint `/teacher/check` с параметрами `task=robot-final` и `answer=вправо`:

`http://kumir-checker:8081/teacher/check?task=robot-final&answer=вправо`

Ответ burp:

```
{
"verdict": "WA",
"expected": "SOLARCTF{n3_s0tv0ri_s3b3_kumir4}","received": "wrong"
}
```

Анализ:
В ответе внутреннего сервиса обнаружено поле "expected", содержащее флаг задания. При этом сервер вернул "verdict: WA" и значение "received: wrong", что указывает на неуспешную проверку ответа.

Таким образом, для получения флага не потребовалось успешно пройти проверку задания: он оказался раскрыт в ответе внутреннего сервиса, доступ к которому был получен через SSRF.

Вывод и аналитика

Тип уязвимости: Server-Side Request Forgery (SSRF).

Причина: функция загрузки аватара позволяет инициировать HTTP-запросы к адресам, заданным пользователем, в том числе к внутренним Docker-сервисам.

Эксплуатация: через SSRF удалось обратиться к внутреннему сервису "kumir-checker:8081". Его диагностический ответ раскрыл endpoint "/teacher/check" и необходимые параметры запроса. При обращении к данному endpoint сервер вернул флаг в поле "expected", несмотря на отрицательный результат проверки ответа.

Последствия: возможность обращаться к внутренним ресурсам через веб-приложение и получать данные, которые не должны быть доступны внешнему пользователю.

Рекомендации по защите:

- Использовать разрешённый список доверенных адресов для загрузки аватаров.
- Проверять IP-адреса после DNS-разрешения и блокировать доступ к локальным, частным и внутренним адресам.
- Контролировать перенаправления, повторно проверяя конечный адрес.
- Ограничивать сетевой доступ веб-приложения к внутренним сервисам на уровне инфраструктуры.